

Security+ 2.2 · Phishing

Mestre CyberSec · Aula 2.2 — Phishing (6:32) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Fraude por email: phishing em massa; Spear phishing = alvo específico com contexto pessoal; Whaling = mirando EXECUTIVO (a baleia); Vishing = por voz (ligação); SMiShing = por SMS. Defesa: MFA, antispam, SPF/DKIM/DMARC (autentica o remetente), awareness.

💡 Highlights que a prova CompTIA cobra

- Whaling = phishing mirando executivo (spear phishing de whale)
- Vishing = phishing por VOZ; SMiShing = por SMS
- SPF/DKIM/DMARC: o trio de autenticação de remetente de email

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'C-level executives target' = whaling
- 'phishing by voice call' = vishing

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Phishing (Phishing em Massa) (N/A)

Ataque de engenharia social baseado em email enviado a um grande número de destinatários sem alvo específico, usando iscas genéricas para roubar credenciais ou distribuir malware.

⚠ **Armadilha CompTIA:** *If the question describes a broad, untargeted email campaign → it's plain 'Phishing'. As soon as it gets personal/targeted, it becomes Spear Phishing.*

• Spear Phishing (Phishing Direcionado) (N/A)

Ataque de phishing direcionado e personalizado com contexto pessoal ou organizacional (nome, cargo, projetos) para aumentar a credibilidade contra um indivíduo ou grupo específico.

⚠ **Armadilha CompTIA:** *Trigger words: 'personalized', 'mentions your name/project', 'targeted individual'. Spear Phishing = targeted; Whaling = spear phishing aimed at executives.*

• Whaling (Phishing de Baleia) (N/A)

Ataque de spear phishing direcionado especificamente a executivos de alto escalão (CEO, CFO) cujo acesso permite grandes fraudes financeiras ou comprometimento estratégico.

⚠ **Armadilha CompTIA:** *Look for 'C-level', 'CEO', 'executive', 'CEO fraud / BEC'. Whaling = spear phishing aimed at the 'whale' (executive). Often paired with Business Email Compromise (BEC).*

• Vishing (Phishing por Voz) (N/A)

Ataque de phishing realizado por chamada telefônica de voz, frequentemente usando spoofing de identificador de chamadas e scripts de urgência para extrair credenciais ou informações sensíveis.

⚠ **Armadilha CompTIA:** *Trigger words: 'phone call', 'caller ID spoofing', 'voice'. 'Phishing by voice call' = Vishing. Distinguish from Smishing (SMS).*

• SMiShing (Phishing por SMS) (N/A)

Ataque de phishing entregue por mensagens de texto SMS, tipicamente contendo links maliciosos ou prompts para ligar para números fraudulentos.

⚠ **Armadilha CompTIA:** *Trigger words: 'text message', 'SMS', 'short code'. The 'SM' = Short Message. Don't confuse SMiShing (SMS) with Vishing (voice call).*

• Sender Policy Framework (SPF)

Registro DNS de autenticação de email que lista os servidores de email autorizados a enviar mensagens em nome de um domínio, ajudando a prevenir falsificação do endereço do remetente.

⚠ **Armadilha CompTIA:** *SPF = authorized SENDING servers (envelope sender). It does NOT validate the visible 'From:' header — that's where DKIM/DMARC come in.*

• DomainKeys Identified Mail (DKIM)

Método de autenticação de email que assina criptograficamente as mensagens, permitindo ao receptor verificar que a mensagem não foi alterada em trânsito e veio do domínio declarado.

⚠ **Armadilha CompTIA:** *DKIM = cryptographic SIGNATURE and integrity check. Pairs with SPF (who can send) and DMARC (policy on what to do when checks fail).*

• Domain-based Message Authentication, Reporting & Conformance (DMARC)

Política de autenticação de email construída sobre SPF e DKIM que instrui os servidores de recebimento sobre como tratar mensagens que falham na autenticação (quarentena, rejeitar ou nenhuma) e fornece relatórios.

⚠ **Armadilha CompTIA:** *DMARC = the POLICY layer. It needs BOTH SPF and/or DKIM to align. Trigger words: 'p=reject', 'p=quarantine', 'policy', 'reporting'. The trio is SPF + DKIM + DMARC.*

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma administradora de banco de dados recebe um email que parece vir de seu gerente direto. A mensagem menciona o projeto de migração do banco de dados da equipe pelo codinome interno, cita uma reunião em que os dois participaram na terça-feira passada e pede para abrir um anexo de 'fatura revisada do fornecedor' antes do fim do dia. O anexo chama-se Invoice_Review.docm. Que tipo de ataque está sendo descrito?

- A) Whaling
- B) Spear phishing
- C) Vishing
- D) Phishing em massa

QUESTÃO 2 · CENÁRIO DE EXAME

O CFO de uma rede hospitalar recebe um email urgente que parece ser do CEO. O CEO é publicamente conhecido por estar embarcando em um voo naquele exato momento, tornando impossível uma confirmação verbal rápida. A mensagem instrui o CFO a transferir US\$ 250.000 para a conta de um novo fornecedor e a manter a transação confidencial 'até o anúncio da aquisição'. O endereço do remetente usa o domínio hsp-network-corp.com em vez do domínio real do hospital. Que tipo de ataque é este?

- A) Whaling
- B) Vishing
- C) SMiShing
- D) Phishing em massa

QUESTÃO 3 · CENÁRIO DE EXAME

Uma analista de contas a pagar recebe uma ligação de alguém que diz trabalhar no service desk de TI. O chamador informa que logins suspeitos foram detectados na conta dela e que ela será bloqueada permanentemente em 10 minutos, a menos que ela informe de volta o código de seis dígitos recém-enviado por SMS ao telefone dela. Que tipo de ataque é este?

- A) SMiShing
- B) Spear phishing
- C) Vishing
- D) Whaling

QUESTÃO 4 · CENÁRIO DE EXAME

Logo após a meia-noite, vários funcionários recebem o mesmo SMS em seus telefones pessoais: 'ALERTA FISCAL: uma restituição de imposto de R\$ 1.240 em seu nome está retida. Confirme seus dados de depósito em até 24 horas em [hxxp://payrol1-verify.example-fin\[.\]net](https://payrol1-verify.example-fin[.]net)'. O link abre um formulário que solicita números de conta bancária e a senha do portal da empresa. Que tipo de ataque é este?

- A) Vishing
- B) SMiShing
- C) Phishing em massa
- D) Whaling

QUESTÃO 5 · CENÁRIO DE EXAME

O gateway de email sinaliza que, durante a noite, 12.000 caixas de correio da organização receberam um email idêntico prometendo um 'vale-presente de US\$ 100 para verificar sua conta'. A mensagem não contém nomes de destinatários, departamentos ou detalhes específicos da empresa, e o link aponta para uma página de coleta de credenciais que imita o login SSO corporativo. Que tipo de ataque melhor descreve esta campanha?

- A) Spear phishing
- B) Whaling
- C) Vishing
- D) Phishing em massa

QUESTÃO 6 · CENÁRIO DE EXAME

Um administrador de e-mail quer que os servidores de correio destinatários na internet verifiquem que apenas sistemas aprovados pela empresa podem enviar e-mails do domínio @corp-exemplo.com. O requisito é publicar um registro DNS TXT que enumere os endereços IP e hostnames autorizados a enviar, para que os destinatários possam rejeitar e-mails falsificados que alegam ser desse domínio. Qual tecnologia fornece essa capacidade?

- A) DKIM
- B) DMARC
- C) SPF
- D) Um registro DNS reverso (PTR) do servidor de e-mail

QUESTÃO 7 · CENÁRIO DE EXAME

Após uma onda de fraudes com faturas, a equipe de segurança pergunta qual controle de autenticação de e-mail assina cada mensagem enviada com uma chave criptográfica cuja contraparte pública é publicada no DNS, permitindo que os servidores destinatários verifiquem que a mensagem veio de um sistema autorizado e que seus cabeçalhos e corpo não foram modificados em trânsito. Qual controle está sendo solicitado?

- A) SPF
- B) DKIM
- C) DMARC
- D) STARTTLS

QUESTÃO 8 · CENÁRIO DE EXAME

Um CISO quer impedir mensagens falsificadas que exibem o domínio da empresa no campo From visível. Dois requisitos devem ser atendidos: os servidores de e-mail destinatários devem colocar em quarentena ou rejeitar mensagens que falhem na autenticação, e a empresa deve receber relatórios agregados mostrando quem está tentando enviar e-mails como o domínio — incluindo sistemas de marketing de terceiros legítimos que ainda não estão autorizados. Qual implementação satisfaz os dois requisitos?

- A) SPF configurado com mecanismo softfail (~all)
- B) Chaves DKIM rotacionadas a cada 90 dias com RSA de 2048 bits
- C) Assinatura DNSSEC da zona da empresa
- D) DMARC publicado com política de quarantine ou reject

QUESTÃO 9 · CENÁRIO DE EXAME

Uma analista de folha de pagamento clicou em um link de um e-mail fraudulento e digitou seu nome de usuário e senha em uma página que imitava o login do Microsoft 365 da empresa. Ela relatou o incidente em minutos, mas o atacante agora possui credenciais válidas. Qual controle já implantado impedirá mais diretamente que o atacante use essas credenciais capturadas para acessar sua caixa de correio?

- A)** Autenticação multifator (MFA)
- B)** Criptografia de disco completo no notebook dela
- C)** Um firewall baseado em host no notebook dela
- D)** Varredura trimestral de vulnerabilidades do servidor de e-mail

QUESTÃO 10 · CENÁRIO DE EXAME

Após um trimestre em que 31% dos funcionários clicaram em links nos exercícios simulados, o gerente de segurança é solicitado a escolher um controle preventivo que reduza as taxas de clique ao longo do tempo e também forneça dados de tendência mensuráveis mostrando quais departamentos continuam mais suscetíveis à engenharia social por e-mail. Qual controle melhor atende a este objetivo?

- A)** Bloquear todos os anexos de e-mail de entrada no gateway
- B)** Forçar troca de senhas de todos os usuários a cada 30 dias
- C)** Treinamento recorrente de conscientização de segurança (awareness) combinado com campanhas de phishing simulado
- D)** Aumentar os limites de armazenamento das caixas de correio para arquivar mais e-mails

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Spear phishing

O email é altamente personalizado (codinome interno do projeto e reunião em comum) e mira uma pessoa específica com contexto social crível — marca registrada do spear phishing. O whaling é uma forma de spear phishing direcionada especificamente a executivos de alto nível (C-level), e a vítima aqui é uma administradora de banco de dados. Vishing é conduzido por voz (ligação telefônica), não por email. O phishing em massa é um disparo genérico e não personalizado enviado a grandes volumes de destinatários e não conteria detalhes privados do projeto.

Questão 2: Alternativa A — Whaling

Os alvos são o CFO (com o CEO personificado) — executivos de alto nível — e o objetivo é uma grande transação financeira fraudulenta com pressão por sigilo. Esta é a definição de whaling (também conhecido como personificação de executivo/fraude do CEO). Vishing envolveria uma ligação de voz. SMiShing é entregue via mensagem de SMS. O phishing em massa é uma campanha genérica e sem direcionamento enviada a grandes quantidades de destinatários, não uma personificação precisa de executivo com domínio parecido.

Questão 3: Alternativa C — Vishing

O ataque é entregue por uma ligação de voz ao vivo — engenharia social conduzida por telefone é vishing. O objetivo real do chamador é coletar o código MFA de uso único, o que indica que o atacante provavelmente já roubou a senha da vítima e precisa do segundo fator para vencer a autenticação multifator. SMiShing é um ataque entregue por SMS; aqui o SMS é apenas o canal legítimo que transporta o código MFA real. Spear phishing é um ataque direcionado por email, e whaling mira executivos de alto nível.

Questão 4: Alternativa B — SMiShing

A mensagem maliciosa é entregue via mensagem de SMS, o que por definição é SMiShing (phishing por SMS). O domínio parecido com caracteres trocados é um truque comum para fazer o link caber no SMS e enganar usuários que o leem rapidamente. Vishing é entregue por ligação de voz, não por mensagem de texto. Phishing em massa refere-se a campanhas de email em grande volume. Whaling mira especificamente executivos, enquanto aqui o telefone de todos os funcionários simplesmente recebe o mesmo disparo.

Questão 5: Alternativa D — Phishing em massa

Uma única mensagem idêntica enviada em massa a milhares de destinatários sem nenhuma personalização é phishing em massa — o atacante depende do volume e de uma pequena porcentagem de cliques em vez de contexto social personalizado. Spear phishing exige detalhes direcionados e pessoais sobre um destinatário específico. Whaling é spear phishing limitado a executivos de alto nível. Vishing seria entregue por ligação de voz; este ataque chegou por email.

Questão 6: Alternativa C — SPF

SPF (Sender Policy Framework) é exatamente este mecanismo: o dono do domínio publica um registro DNS TXT listando os endereços IP e hostnames autorizados a enviar e-mails pelo domínio, e os servidores destinatários verificam o servidor remetente real contra essa lista. DKIM adiciona uma assinatura criptográfica a cada mensagem em vez de autorizar hosts de envio. O DMARC usa os resultados de SPF e DKIM para aplicar política e gerar relatórios, mas não enumera remetentes autorizados. Um registro PTR suporta resolução reversa e pontuação de reputação, mas não enumera os remetentes aprovados de um domínio.

Questão 7: Alternativa B — DKIM

DKIM (DomainKeys Identified Mail) anexa uma assinatura digital a cada mensagem; a chave pública é publicada no DNS e os destinatários validam a assinatura para confirmar tanto que o domínio remetente autorizou a mensagem quanto que o conteúdo não foi violado (integridade). O SPF apenas verifica se o endereço IP remetente é autorizado — ele não assina mensagens nem protege o conteúdo. O DMARC é uma camada de política e relatórios sobre o alinhamento de SPF e DKIM e não realiza a assinatura em si. STARTTLS criptografa a sessão SMTP em trânsito, mas é oportunista, não produz assinatura persistente verificável e não prova a autenticidade do conteúdo.

Questão 8: Alternativa D — DMARC publicado com política de quarantine ou reject

O DMARC (Domain-based Message Authentication, Reporting & Conformance) atende aos dois objetivos: permite que o dono do domínio defina o que os destinatários devem fazer quando SPF/DKIM falham em alinhar com o domínio visível no From

(p=quarantine ou p=reject), e envia relatórios agregados e forenses de volta ao dono do domínio, revelando remetentes não autorizados — frequentemente serviços de terceiros legítimos — para que possam ser identificados e autorizados. O SPF softfail apenas marca o e-mail como suspeito e não gera relatórios. A rotação de chaves DKIM fortalece as assinaturas, mas não define política para falha de autenticação. O DNSSEC protege a integridade das consultas DNS da zona, não a política de remetentes de e-mail nem os relatórios.

Questão 9: Alternativa A — Autenticação multifator (MFA)

O MFA exige um fator adicional que o atacante não possui — como um código de app autenticador, um token de hardware ou uma biometria — então uma senha roubada sozinha não é suficiente para o login, o que torna o MFA o controle compensatório mais eficaz contra credenciais obtidas por phishing. A criptografia de disco protege dados em repouso em um dispositivo roubado, não o acesso à conta a partir de qualquer local. Um firewall de host filtra o tráfego de rede do endpoint e não impede o reuso de credenciais a partir da máquina do atacante. A varredura de vulnerabilidades busca falhas de software no servidor de e-mail, que nunca foi comprometido — apenas as credenciais dela foram.

Questão 10: Alternativa C — Treinamento recorrente de conscientização de segurança (awareness) combinado com campanhas de phishing simulado

O treinamento de conscientização de segurança (awareness) combinado com campanhas de phishing simulado ataca diretamente a vulnerabilidade humana que o phishing explora. Campanhas repetidas e mensuráveis comprovadamente reduzem as taxas de clique ao longo do tempo e geram métricas de tendência por usuário e por departamento que podem ser reportadas à liderança — exatamente o resultado mensurável solicitado. Bloquear todos os anexos quebra fluxos legítimos de trabalho e cobre apenas um vetor de entrega, não o comportamento de clique. Trocas forçadas e periódicas de senha são orientação obsoleta do setor e não impedem que o usuário digite credenciais em uma página de login falsa. Cotas maiores de e-mail não têm impacto de segurança sobre a suscetibilidade ao phishing.